

Advanced SQL Injection & Role-Based Access Control (RBAC)

Name: Nguyen Thi Hai Yen

ID: 11247252

Lab 1: Implementing RBAC

```
44 -- 1. Create theGroup Role
45 CREATE ROLE cashier_role;
46
```

Data Output Messages Notifications

CREATE ROLE

Query returned successfully in 65 msec.

```
47 -- 2. Create User Accounts
48 drop user if exists mike;
49 drop user if exists jon;
50 CREATE USER mike WITH PASSWORD 'mike123';
51 CREATE USER jon WITH PASSWORD 'jon123';
52
```

Data Output Messages Notifications

CREATE ROLE

Query returned successfully in 60 msec.

```
53 -- 3. Assign Users to theGroup
54 GRANT cashier_role TO mike;
55 GRANT cashier_role TO jon;
56
```

Data Output Messages Notifications

GRANT ROLE

Query returned successfully in 51 msec.

```
57 -- 4. Assign Table Permissions to theGroup
58 GRANT SELECT ON film, staff TO cashier_role;
59 GRANT SELECT, INSERT ON payment TO cashier_role;
```

Data Output Messages Notifications

GRANT

Query returned successfully in 51 msec.

```

62 SET ROLE Mike;
63
64 -- Mike runs a simple SELECT ALL
65 SELECT * FROM staff;

```

	staff_id [PK] integer	first_name character varying (45)	last_name character varying (45)	address_id smallint	email character varying (50)
1	1	Mike	Hillyer	3	Mike.Hillyer@sakilastaff.com
2	2	Jon	Stephens	4	Jon.Stephens@sakilastaff.c...
3	3	Nguyen	An	1	nguyen.an@example.com

Lab 2: Implementing RLS

```

69 -- Lab 2
70 --1. Enable RLS on the table
71 ALTER TABLE payment ENABLE ROW LEVEL SECURITY;
72

```

Data Output	Messages	Notifications
ALTER TABLE		
Query returned successfully in 53 msec.		

```

73 --2. Create the Policy
74 CREATE POLICY isolate_cashier_payments ON payment
75 FOR SELECT
76 TO cashier_role
77 USING (
78   staff_id = (SELECT staff_id FROM staff WHERE username = current_user)
79 );
80

```

Data Output	Messages	Notifications
CREATE POLICY		
Query returned successfully in 49 msec.		

```
82 --3. Testing the Policy
83 SET ROLE mike; -- Switch context toMike
84 SELECT COUNT(*) FROM payment; -- Returns 7292 (Mike's payments only)
85
```

Data Output Messages Notifications

         SQL

Showing rows: 1 to 1 

	count bigint 
1	7294

```
86 SET ROLE jon; -- Switch context to Jon
87 SELECT COUNT(*) FROM payment; -- Returns 7304 (Jon's payments only)
```

Data Output Messages Notifications

         SQL

Showing rows: 1 to 1 

	count bigint 
1	7304